

Security At AI Speed: Metrics That Actually Steer

A Phase- And Domain-Aligned Approach to Measuring Decision Latency, Not Just Control Coverage

Why Another Metrics Paper

Most cybersecurity metric catalogs fail in the same way: they are exhaustive lists of everything that *can* be measured, presented without a sense of when each measurement matters or when it stops mattering. The result is a dashboard with sixty indicators that nobody reads, a board pack that obscures more than it reveals, and a CISO who cannot tell whether the security program is improving or merely busy.

The problem is not that the metrics are wrong. It is that they are presented as a static set when they are, in reality, a sequence. A security program that has just enforced MFA ¹ needs to measure MFA adoption. A program three years in, where MFA has been at 100% for years and most authentication is passwordless, gains nothing from continuing to report it.

This paper aligns directly to the *Security at AI Speed* Implementation Guide. It uses the same four phases — Act Now, Short Term, Mid Term, Beyond — and the same six operating domains — Governance, Organization & Culture, SOC ² / SecOps ³, Architecture, Identity / Access, Data / Visibility. The aim is to give every milestone in the Implementation Guide a measurable counterpart, and to do so without inflating the metric set: each phase brings new metrics in, and **retires** earlier metrics whose signal has run out.

If the foundational argument of the series is that *decision latency*, not control coverage, is the primary risk driver at AI speed, the metric set has to mirror that. Coverage indicators dominate the early phases. Outcome and latency indicators take over later. By the *Beyond* phase, what is left on the dashboard is the small number of measurements that prove the business is resilient under attack.

Three Principles

1. Coverage metrics expire

Any metric trending towards 100% is a transitional indicator. Once it gets there, it stops carrying signal — a flatline at 100% is indistinguishable from a flatline caused by stopped measurement. Coverage metrics should be designed with an explicit successor in mind: MFA adoption becomes phishing-resistant MFA coverage becomes passwordless coverage. Each one retires the previous, and the board sees a single evolving identity-strength indicator rather than three parallel ones that all read "100%".

2. Activity metrics get replaced by outcome metrics

Early in a program, activity is the only honest signal: how many alerts were triaged, how many controls were tested, how much training was completed. These build the muscle. Once the muscle exists, the board no longer cares whether 70% of alerts were triaged by automation — it cares whether the business was disrupted. The set must shift from *did we do the work* to *did the work produce the outcome*.

3. New control planes create new metrics

AI agents, security graphs, and federated defense partnerships did not exist as control planes a decade ago. They do now. Each one brings its own coverage, effectiveness, and outcome metrics — and they are not optional once the control plane carries real risk. AI agents acting on behalf of humans require lifecycle metrics for the same reason humans require joiner-mover-leaver. The set grows where the attack surface grows.

Phase 1 — Act Now (0–3 months)

Implementation Guide intent: establish a continuous, business-aligned governance baseline; clarify roles; stabilize the current SOC and remove manual bottlenecks; define "minutes matter" KPIs ⁴; enforce baseline identity controls; centralize logs; identify crown jewels.

What metrics are for here: prove the foundations exist and are owned. Almost all leading, almost all coverage-based.

Domain	Metric	Target	Type	Lifecycle Note
Governance	Risk Ownership Documentation	100% of top-tier risks have a named, accountable owner	Leading	Stays
Governance	Risk Acceptance Sign-Off Rate	100%, signed by the person accountable to the board	Leading	Stays
Governance	AI Guardrail Policy in Force	Yes / No (binary milestone)	Leading	Retires Short Term — binary milestone met; succeeded by AI Model Audit Coverage in Mid Term
Org & Culture	Decision Rights Defined (CISO / SOC / Data / AI)	RACI ⁵ published and acknowledged	Leading	Stays
Org & Culture	Board / Executive Cyber Cadence	Quarterly board / Monthly executive in place	Leading	Stays
SOC / SecOps	Manual Triage Share	Baselined and trending down	Lagging	Retires Short Term — replaced by AI-assisted triage rate
SOC / SecOps	"Minutes Matter" KPI Baseline	MTTD ⁶ baselined per attack vector	Leading	Retires Short Term — replaced by live MTTD / MTTR ⁷ targets

Domain	Metric	Target	Type	Lifecycle Note
Architecture	Zero Trust Principles Documented	Yes / No	Leading	Retires Short Term — milestone met; folds into security graph integration
Architecture	Critical Architecture Gap Inventory	100% of crown-jewel paths reviewed	Leading	Retires Short Term — becomes continuous graph-based coverage
Identity / Access	Phishing-Resistant MFA — Privileged Accounts	100%	Leading	Stays — extends to all users in Short Term
Identity / Access	Standing Privilege Inventory	100% of privileged accounts cataloged	Leading	Retires Short Term — feeds JIT ⁸ and least-privilege metrics
Data / Visibility	Log Centralization Coverage	> 60% of critical sources into the data lake	Leading	Retires Short Term — replaced by data lake coverage at > 80%
Data / Visibility	Crown-Jewel Data Identified	100% (typically 1–3% of total data)	Leading	Stays — feeds security graph and predictive use cases

Deliberately absent at Act Now. Anything graph-based, AI-agent identity, autonomous response, or red-team-derived. Measuring control planes that do not yet exist is performative and steers the wrong way.

Phase 2 — Short Term (6–8 months)

Implementation Guide intent: operationalize governance as a continuous cadence; formalize the operating model; introduce AI-assisted detection; move response time towards minutes; adaptive identity; mature the data lake with cross-domain correlation.

What metrics are for here: shift from *do controls exist* to *are they working continuously and fast enough*. Speed enters the dashboard.

Domain	Metric	Target	Type	Lifecycle Note
Governance	Continuous Compliance Monitoring Coverage	> 80% of in-scope controls	Leading	Stays
Governance	Cyber Risk Integrated into ERM ⁹ Register	100%	Leading	Stays
Governance	Decision Cycle Time (risk decision)	< 7 days critical / < 30 days standard	Lagging	Tightens in Mid Term

Domain	Metric	Target	Type	Lifecycle Note
Org & Culture	Security Embedded in Transformation Programs	> 70% of programs have a named security owner at design	Leading	Stays
Org & Culture	Phishing Reporting Rate	> 70%	Leading	Stays
SOC / SecOps	AI-Assisted Triage Rate	> 50% of alerts initially triaged by AI	Leading	Retires Beyond — becomes default behavior
SOC / SecOps	Mean Time to Detect (critical)	< 24h overall / < 1h identity	Lagging	Stays — target collapses
SOC / SecOps	Mean Time to Respond (critical)	< 1 hour	Lagging	Stays — target collapses
SOC / SecOps	Threat Intelligence Operationalization	> 70% of feeds enriched into SOC workflows	Leading	Stays
Architecture	Identity / Data / SOC Integration Milestones	All three planes connected to a single security graph	Leading	Stays
Architecture	Conditional Access Coverage (critical apps)	100%	Leading	Retires Mid Term — replaced by continuous-verification coverage
Identity / Access	Phishing-Resistant MFA — All Users	> 80%	Leading	Retires Beyond as passwordless dominates
Identity / Access	Least Privilege Enforcement	> 90% of accounts within defined entitlement boundaries	Leading	Stays
Identity / Access	Just-in-Time Access for Privileged	> 90%	Leading	Stays
Data / Visibility	Data Lake Coverage	> 80% of telemetry sources	Leading	Stays — target rises to > 95%
Data / Visibility	Cross-Domain Correlation Coverage	> 60% of incidents enriched across ≥ 3 domains	Leading	Stays

Retires from Act Now. *AI Guardrail Policy in Force* (binary milestone met; succeeded by AI Model Audit Coverage in Mid Term), *Manual Triage Share* (replaced by AI-assisted triage rate), the *"Minutes Matter" KPI Baseline* milestone (replaced by live MTTD / MTTR targets), *Log Centralization Coverage* (replaced by data lake coverage), *Zero Trust Principles Documented* and *Critical Architecture Gap Inventory* (one-off architecture milestones, now folded into security graph integration), and *Standing Privilege Inventory* (feeds JIT and least-privilege metrics).

Phase 3 — Mid Term (9–12 months)

Implementation Guide intent: governance becomes a decision engine; SOC moves proactive / pre-breach; AI agents take assisted or autonomous actions; identity becomes the primary control plane and extends to workloads, APIs ¹⁰, and AI agents; the data platform supports predictive use cases.

What metrics are for here: prove the operating loop works at pace, and that new control planes — AI agents, identity-for-machines, security graph — are governed at the same bar as humans.

Domain	Metric	Target	Type	Lifecycle Note
Governance	Continuous Improvement Loop Cycle Time	< 30 days from finding to closed action	Lagging	Stays
Governance	Pre-Authorized Containment Action Coverage	> 60% of high-severity playbooks pre-authorized	Leading	Direct measure of <i>pre-authored authority</i>
Governance	AI Model Audit Coverage (high-risk models)	100%	Leading	EU AI Act locks this in
Org & Culture	Embedded Security in Product / IT Teams	> 1 named security partner per major product line	Leading	Stays
Org & Culture	Cross-Functional Incident Drill Frequency	≥ 4 per year	Leading	Stays
SOC / SecOps	Mean Time to Contain (critical)	< 15 minutes	Lagging	Headline operational metric
SOC / SecOps	Automated Response Coverage	> 60% of incidents with automated containment	Leading	Stays — target rises
SOC / SecOps	Analyst Time on Proactive Hunting	> 30%	Leading	Stays

Domain	Metric	Target	Type	Lifecycle Note
SOC / SecOps	Breakout Time Prevention Rate	> 85% of incidents contained pre-lateral-movement	Leading	Becomes headline outcome in Beyond
Architecture	Security Graph Relationship Coverage	> 70% of crown-jewel assets with mapped dependencies	Leading	Stays — target rises
Architecture	Critical Service-to-Architecture Alignment	100% of critical business services mapped to defending controls	Leading	Stays
Identity / Access	Identity as Primary Access Decision Plane	> 90% of access decisions evaluated against identity context	Leading	Stays
Identity / Access	Non-Human Identity Coverage (workloads, APIs, AI agents)	> 80%	Leading	New control plane
Identity / Access	Passwordless Authentication Coverage	> 70% of authentication events	Leading	Stays — target rises
Data / Visibility	High-Fidelity Correlation Rate	> 80% of detections corroborated by ≥ 2 independent sources	Lagging	Stays
Data / Visibility	Predictive / Pre-Emptive Use Cases Live	≥ 3 production use cases	Leading	Stays

Retires from Short Term. *Conditional Access Coverage* (subsumed by continuous identity verification), the *Continuous Compliance Monitoring Coverage* milestone (now expected, not measured), and the *Threat Intelligence Operationalization* coverage metric (replaced by outcome-based intel metrics in Beyond).

Phase 4 — Beyond (12+ months)

Implementation Guide intent: machine-speed SOC fully realized with autonomous or semi-autonomous response; governance adaptive and predictive with real-time risk visibility; identity-driven security for all entities; continuous collaboration with the external ecosystem; predictive analytics and automated decisioning.

What metrics are for here: the dashboard is now small. Activity metrics are gone. Only outcome, latency, and resilience indicators remain — the ones the board uses to allocate capital and the CISO uses to defend the model under pressure.

Domain	Metric	Target	Type
Governance	Real-Time Risk Posture Available to Board on Demand	Yes — live, not periodic	Leading
Governance	Pre-Authorized Containment Action Coverage	> 90% of high-severity playbooks	Leading
Governance	Risk-Decision Latency (detection → board-aware → decision)	< 1 hour for systemic incidents	Lagging
Org & Culture	Resilience / Crisis Drill Cadence	≥ 4 per year, with executive participation	Leading
Org & Culture	Time to Re-Establish Decision Authority Post-Incident	< 30 minutes	Lagging
SOC / SecOps	Mean Time to Detect (critical)	< 1 hour overall / < 5 minutes identity	Lagging
SOC / SecOps	Mean Time to Respond (critical)	< 15 minutes	Lagging
SOC / SecOps	Breakout Time Prevention Rate	> 95%	Leading — headline outcome
SOC / SecOps	Incident Containment Without Business Impact	> 85%	Lagging
SOC / SecOps	Autonomous Response Coverage	> 50% of qualifying incidents handled end-to-end by agents, with human-on-the-loop	Leading
Architecture	Security-By-Design Adherence	> 90% of new systems pass design-time security validation	Leading
Architecture	Security Graph Relationship Coverage	> 90% of all assets	Leading
Identity / Access	Passwordless Authentication Coverage	> 95% of authentication events	Leading
Identity / Access	Continuous Verification Adoption	100% of high-risk access flows	Leading
Identity / Access	AI Agent Lifecycle Compliance	100% (provision, monitor, deprovision)	Leading

Domain	Metric	Target	Type
Data / Visibility	Real-Time Organization-Wide Visibility	Single pane covering identity, endpoint, cloud, network, data, AI	Leading
Data / Visibility	Joint Exercise Participation (collective defense)	≥ 4 per year	Leading
Data / Visibility	Indicators Received vs Shared Ratio	0.8 – 1.2 (reciprocity)	Leading

Retires from Mid Term. *AI-Assisted Triage Rate* (automation is the default, not a measurement), *Phishing-Resistant MFA — All Users* (collapsed into passwordless coverage), and the *Pre-Authorized Containment Action Coverage* leading metric (the target is now > 90% and the indicator becomes a near-flatline).

The Lifecycle, Read Vertically

The point of the four tables above is not the metrics themselves — they exist in any reasonable catalog. The point is the **rightmost column**. Read vertically, it tells a story most metric programs never articulate: the dashboard a CISO steers with in *Beyond* should not look like the dashboard from *Act Now* with more rows added. It should look different, because the questions are different.

Phase	The Question The Dashboard Answers
Act Now	Do the controls and accountabilities exist?
Short Term	Are the controls working continuously and fast enough?
Mid Term	Is the operating loop closing under pressure, and are new control planes governed at the same bar as human ones?
Beyond	Is the business resilient under AI-speed attack, and can the decision system run faster than the attacker?

Each phase's metrics are designed for the question of that phase. Carrying *Act Now* metrics into *Beyond* is not conservative — it is misleading. It tells the board that the program is still proving controls exist when the relevant question is whether the business survives the next incident.

A Note On What Was Left Out

A catalog approach tempts every author into completeness. The set in this paper is deliberately around a third of what a full catalog would contain. Items intentionally excluded include:

- **Failed login attempt rate.** Useful inside the SOC as an alert threshold; not useful at board level. The concept itself becomes ambiguous once passwordless dominates.
- **Backup success rate.** Critical to measure inside operations; reported to the board only when it dips. A 99.5% number is not a steering metric — a missed RTO ¹¹ during a real incident is.
- **Policy violation counts.** Activity metric. Tells you something is happening; tells you nothing about

whether risk is rising or falling.

- **DLP ¹² incident counts.** A declining count can mean controls are working, or that the controls have been bypassed and you no longer see the incidents. Use only with corroborating signal.

These are not bad metrics. They are operational metrics. The set above is the *steering* set — what a CISO presents upward and what a board uses to allocate capital.

Closing

Metrics are the language in which security translates into business decisions. Choosing the wrong language, or refusing to change it as the program matures, is one of the most common reasons security loses board confidence even when the underlying program is improving.

At AI speed, the deeper risk is more specific. If the dashboard is dominated by coverage and activity indicators, the board cannot see decision latency. And decision latency is what the attacker is exploiting. The phase- and domain-aligned set in this paper is offered as a starting point — not a final answer — that keeps the dashboard small, keeps the indicators honest, and keeps the focus on the one thing the *Security at AI Speed* series argues matters most: the speed at which the organization can see, decide, and act.

If the board sees the same dashboard in *Beyond* that it saw in *Act Now*, the dashboard is wrong.

Footnotes

1. **MFA** — Multi-Factor Authentication. Requires two or more verification factors (something you know, have, or are) at sign-in. [↗](#)
2. **SOC** — Security Operations Center. The team and platform responsible for monitoring, detecting, investigating, and responding to security events. [↗](#)
3. **SecOps** — Security Operations. The broader operating discipline that includes the SOC plus engineering, threat intelligence, incident response, and continuous improvement. [↗](#)
4. **KPI** — Key Performance Indicator. A measurable value used to evaluate whether a program is meeting a defined objective. [↗](#)
5. **RACI** — Responsible, Accountable, Consulted, Informed. A decision-rights mapping that names who does the work, who owns the outcome, who must be consulted, and who must be kept informed. [↗](#)
6. **MTTD** — Mean Time to Detect. Average elapsed time between threat entry and the moment the defender becomes aware of it. [↗](#)
7. **MTTR** — Mean Time to Respond. Average elapsed time from detection to containment. [↗](#)
8. **JIT** — Just-in-Time access. Privileges granted only for the duration of a specific task and revoked automatically when the task completes, eliminating standing privilege. [↗](#)
9. **ERM** — Enterprise Risk Management. The corporate-level framework that aggregates and prioritizes all categories of risk (financial, operational, regulatory, cyber, strategic) for board oversight. [↗](#)
10. **API** — Application Programming Interface. A defined contract that allows software components, services, or AI agents to interact programmatically. [↗](#)
11. **RTO** — Recovery Time Objective. The maximum acceptable downtime for a critical service before business impact is deemed unacceptable. The companion metric is RPO (Recovery Point Objective), the maximum acceptable data loss measured in time. [↗](#)
12. **DLP** — Data Loss Prevention. Controls that detect and block sensitive data from leaving sanctioned channels, environments, or jurisdictions. [↗](#)